

KỊCH BẢN QUẢN LÝ TRUY CẬP

(Chỉ sử dụng cho mục đích học tập và huấn luyện nhận thức trong môi trường lab; nghiêm cấm áp dụng để tấn công hệ thống thực tế)

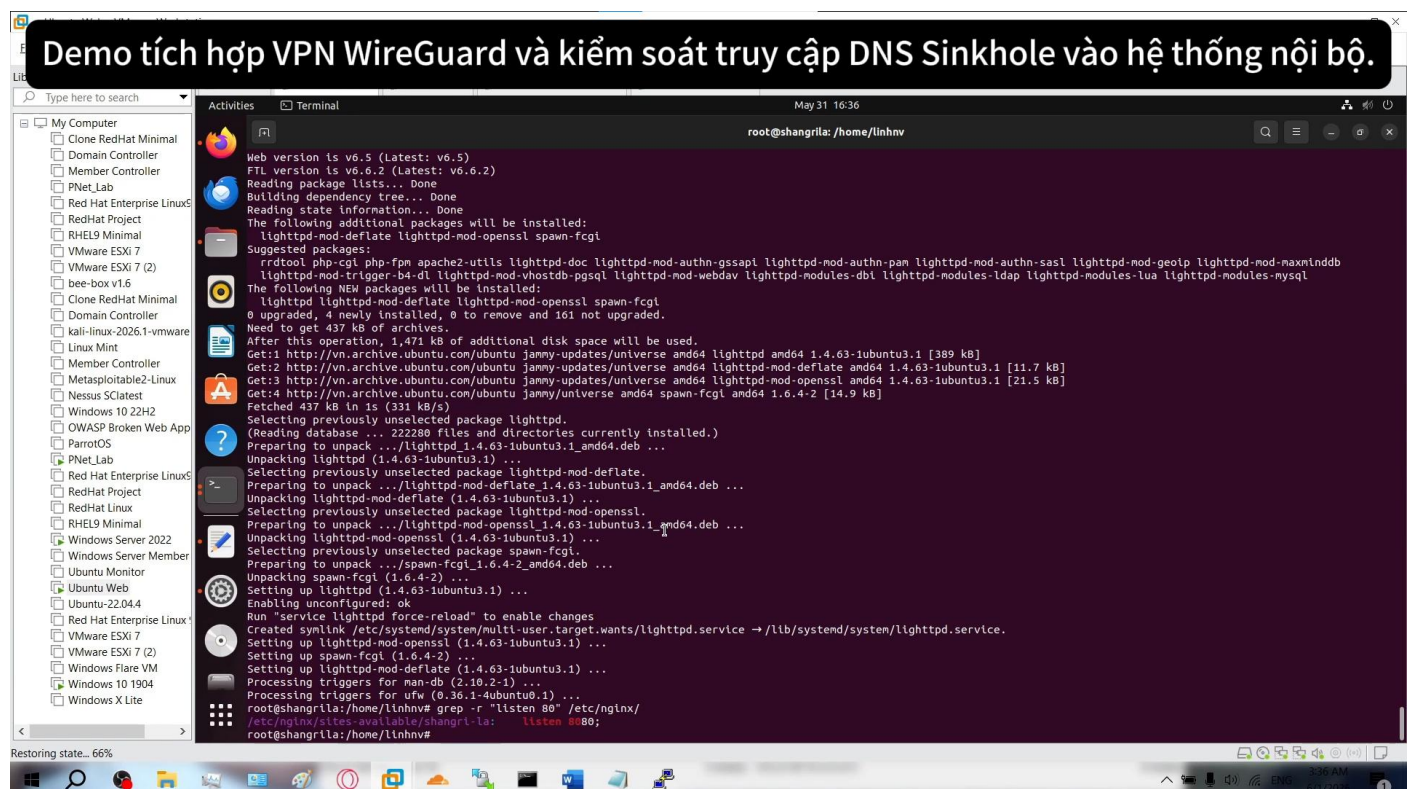
Kỹ thuật kiểm soát truy cập bằng WireGuard VPN và DNS Sinkhole là phương pháp mà Đội phòng thủ (Blue Team) dùng các tính năng mã hóa đường truyền của VPN phối hợp với cơ chế phân giải tên miền của Pi-hole để thiết lập vành đai bảo mật. Kỹ thuật này giúp chuyển hướng các truy vấn tên miền độc hại hoặc không mong muốn về một địa chỉ IP ảo (Sinkhole), đồng thời chỉ cho phép các thiết bị kết nối qua đường hầm mã hóa mới có quyền tiếp cận các tài nguyên nội bộ thay vì để lộ các dịch vụ quản trị trực tiếp ra Internet.

Hệ thống Lab bao gồm:

- **Máy chủ Webserver & DNS Sinkhole:** Chạy dịch vụ Pi-hole đóng vai trò làm máy chủ quản lý danh sách tên miền chặn và định tuyến truy cập nội bộ
- Thiết lập dải mạng bảo mật riêng biệt (10.66.66.0/24) cho các máy trạm từ xa kết nối về hệ thống.
- Các máy trạm Client:

Bước 1: Chuẩn bị môi trường & Thiết lập dịch vụ

- Quản trị viên cài đặt và cấu hình dịch vụ Pi-hole trên nền tảng Linux làm DNS nội bộ, đồng thời khởi tạo máy chủ HTTP hoạt động ở cổng 8080 (thay vì cổng 80 mặc định) để nhường quyền quản trị cho giao diện Pi-hole.



- # Thao tác nhằm ép phân giải tên miền đi qua đường hầm mã hóa và kiểm soát của Pi-hole

- Để bảo vệ dịch vụ web nội bộ khỏi các truy cập trái phép từ Internet, quản trị viên thiết lập quy tắc tường lửa chỉ cho phép dải IP thuộc VPN tiếp cận cổng dịch vụ.
- **Lệnh thực thi:** `sudo ufw insert 1 allow from 10.66.66.0/24 to any port 8080`
- **Kết quả:** Tường lửa được cập nhật, chặn toàn bộ các IP bên ngoài mạng VPN truy cập vào cổng hệ thống. Máy trạm khi chưa kết nối VPN sẽ nhận thông báo lỗi *ERR_CONNECTION_REFUSED*.

The screenshot shows a Linux desktop environment. At the top, a large black banner contains the text: "Thiết lập rule Ưu tiên 1, chỉ cho phép IP (10.66.66.0/24) được truy cập vào Port 80/8080". Below the banner, the desktop is divided into several windows:

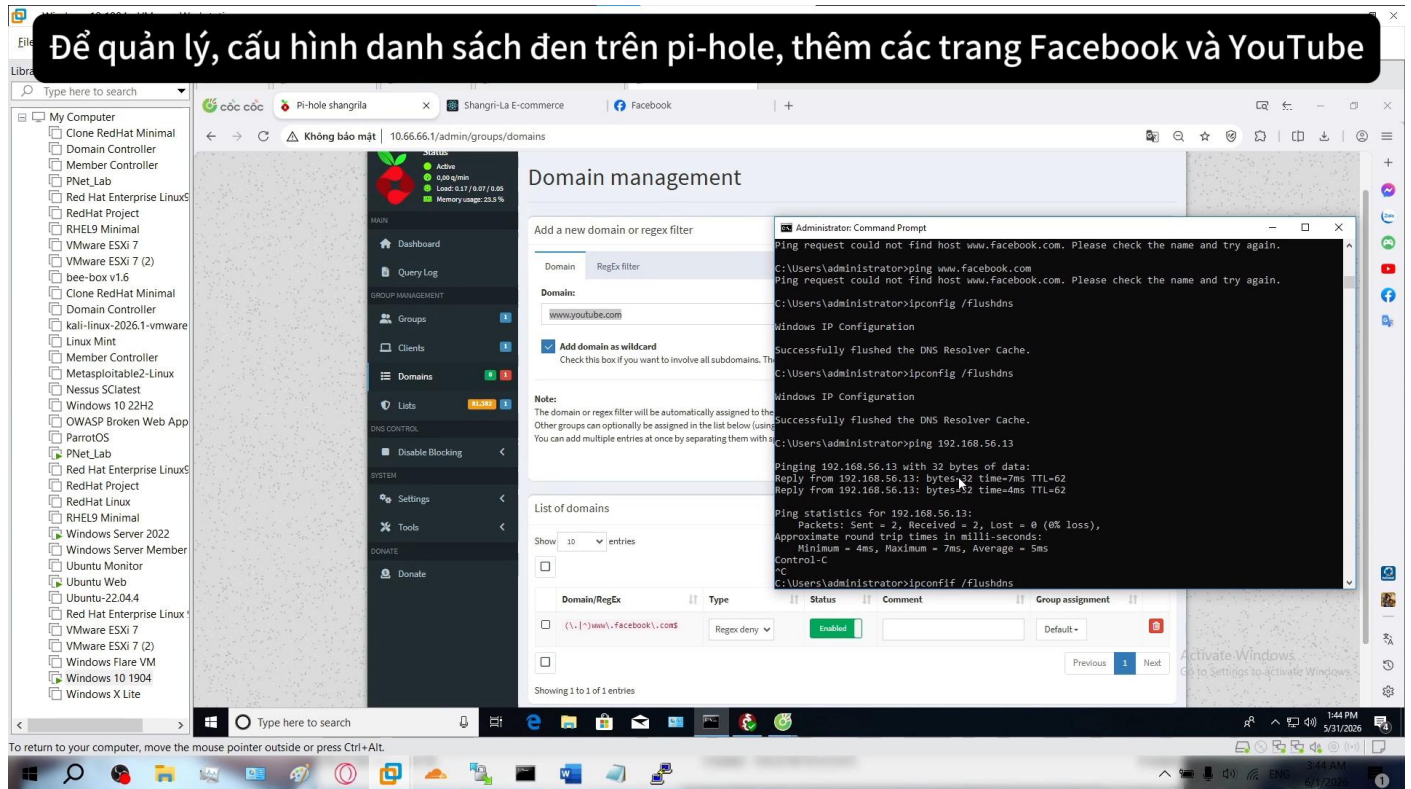
- Terminal Window:** Displays the execution of the following commands:


```

      root@shangrila: /home/linhvv
      app default ARG
      set default application policy
      install.sh
      4 chmod +x /etc/default/apparmor
      5 sudo systemctl restart apparmor
      6 sudo ./wreguard/firewall_reload
      7 DNS = 10.66.66.10
      8 AllowedIPs = 10.66.66.0/24
      9
      10 sudo ufw reset
      11 sudo ufw delete 11 8081
      12 sudo ufw delete 12 80
      13 sudo ufw --force 13 53/udp
      14 sudo ufw insert 14 53/tcp
      15 sudo ufw append 15 53/udp (v6)
      16 sudo ufw allow 16 53/tcp (v6)
      17 sudo ufw allow 17 53/udp (v6)
      18 sudo ufw reload
      19
      20 http://192.168.56.13:8080
      21 root@shangrila: /home/linhvv# sudo ufw insert 1 allow from 10.66.66.0/24 to any port 8080
      22 Rule inserted
      23 root@shangrila: /home/linhvv# sudo ufw reload
      24 sudo apt install ufw
      25 sudo chown -R www-data:www-data /var/www/html/admin
      26
      27 sudo systemctl stop nginx
      28 sudo nano +46 /etc/lighttpd/lighttpd.conf
      29 sudo systemctl restart lighttpd
      30 sudo phole -r
      31 server.port := 8080
      32
      33 sudo phole -r
      34 sudo apt-get purge --auto-remove lighttpd -y
      35 sudo rm -rf /etc/lighttpd
      36 sudo rm -rf /etc/phole
      37 sudo rm -rf /etc/.phole
      38 sudo rm -rf /var/www/html/admin
      39
      
```
- Web Browser Window:** Shows the "Pi-hole shangrila" dashboard. It displays statistics: "Queries Blocked" (19), "Percentage Blocked" (3.2%), and "Client activity" (1 active clients). The "DNS CONTROL" section shows "Disable Blocking" is enabled.
- File Manager Window:** Shows the "My Computer" view with a list of files and folders, including "Clone RedHat Minimal", "Domain Controller", "Member Controller", "PNet_Lab", "Red Hat Enterprise Linux", "RedHat Project", "RHEL9 Minimal", "VMware ESXi 7", "VMware ESXi 7 (2)", "bee-box v1.6", "Clone RedHat Minimal", "Domain Controller", "kali-linux-2026.1-vmware", "Linux Mint", "Member Controller", "Metasploitable2-Linux", "Nessus SCiast", "Windows 10 22H2", "OWASP Broken Web App", "ParrotOS", "PNet_Lab", "Red Hat Enterprise Linux", "RedHat Project", "RHEL9 Minimal", "Windows Server 2022", "Windows Server Member", "Ubuntu Monitor", "Ubuntu Web", "Ubuntu-22.04.4", "Red Hat Enterprise Linux", "VMware ESXi 7", "VMware ESXi 7 (2)", "Windows Flare VM", "Windows 10 1904", and "Windows X Lite".

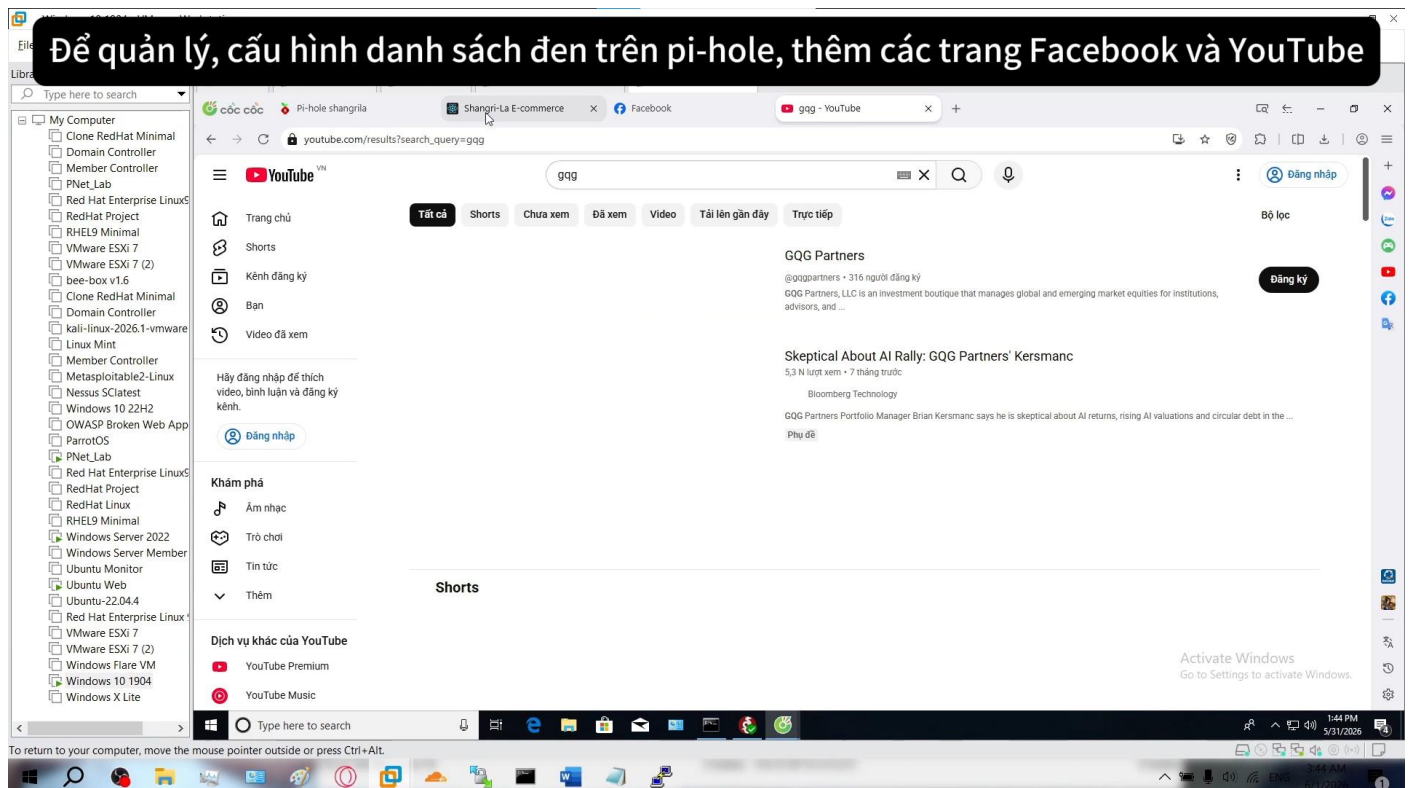
Bước 3: Cấu hình danh sách tên miền chặn trên DNS Sinkhole

- Quản trị viên truy cập vào giao diện quản trị của Pi-hole (<http://192.168.56.13/admin>) để tiến hành quản lý danh bạ tên miền độc hại hoặc các trang mạng xã hội không cho phép trong giờ làm việc.
- Tiến hành thêm các tên miền mục tiêu như `facebook.com` và `youtube.com` vào danh sách cấm (Blocklist/Domain Management) với trạng thái *RegEx deny*.



Bước 4: Kiểm thử truy cập khi chưa kích hoạt WireGuard VPN

- Người dùng trên máy trạm thực hiện truy cập trực tiếp vào địa chỉ IP của Webserver hoặc thử kết nối tới các trang mạng xã hội qua trình duyệt web thông thường.



- Kết quả: Do chưa nằm trong dải mạng VPN được ưu tiên, truy cập tới Webserver bị từ chối hoàn toàn. Trong khi đó, các truy vấn tới facebook.com và youtube.com lập tức bị DNS Sinkhole của Pi-hole chặn đứng, trình duyệt hiển thị lỗi *ERR_TIMED_OUT*

Truy cập Facebook và YouTube từ máy trạm đã bị chặn đứng sau một khoảng thời gian."

The screenshot shows the Pi-hole web interface. On the left is a sidebar with navigation options like Dashboard, Query Log, Groups, Clients, Domains, Lists, DNS CONTROL, and SYSTEM. The main area displays 'Recent Queries' with a table of blocked requests. The table has columns for Time, Type, Domain, Client, and a status icon. Queries for youtube.com and facebook.com are shown as blocked (red status icon).

Time	Type	Domain	Client	Status
2026-05-31 13:19:54	AAAA	www.youtube.com	10.66.66.2	Blocked (2.1 μs)
2026-05-31 13:19:54	A	www.youtube.com	10.66.66.2	Blocked (15.7 μs)
2026-05-31 13:19:48	AAAA	www.youtube.com	10.66.66.2	Blocked (16.5 μs)
2026-05-31 13:19:48	A	www.youtube.com	10.66.66.2	Blocked (14.5 μs)
2026-05-31 13:19:46	AAAA	region1.v2.argotunnel.com	localhost	Allowed (3.3 μs)
2026-05-31 13:19:46	A	region1.v2.argotunnel.com	localhost	Allowed (17.4 μs)
2026-05-31 13:19:42	AAAA	www.facebook.com	10.66.66.2	Blocked (10.5 μs)
2026-05-31 13:19:42	A	www.facebook.com	10.66.66.2	Blocked (19.8 μs)

Bước 5: Kiểm tra hiệu quả bảo mật sau khi kết nối VPN

- Sau khi đường hầm mã hóa được thiết lập, máy trạm tiến hành tải lại trang và thực hiện các câu lệnh kiểm tra định tuyến.
- Kết quả: Máy trạm truy cập thành công vào trang Webserver Shangri-la nội bộ do đã thỏa mãn luật tường lửa. Đồng thời, mọi lưu lượng duyệt web đều được kiểm soát chặt chẽ qua Pi-hole; các trang web nằm trong danh sách đen vẫn tiếp tục bị Sinkhole chặn đứng để đảm bảo an toàn thông tin.

Khi kết nối VPN mới được truy cập vào trang Pi-hole và Webserver Shangri-la nội bộ

The screenshot shows the Shangri-La E-commerce Admin System interface. The top bar includes a search bar, user profile, and navigation links. The main content area displays 'Newest Orders' with a table of orders. The table has columns for ORDER ACCOUNT, CONTACT INFO, PRODUCTS, TOTAL AMOUNT, and STATUS & ACTION. Three orders are listed, all with a 'Confirmed' status.

ORDER ACCOUNT	CONTACT INFO	PRODUCTS	TOTAL AMOUNT	STATUS & ACTION
vietlinhn22@gmail.com	VIETLINH 0374954103 vietlinhn22@gmail.com HCM HCM	iPhone 17r 256GB	24,990,000 VND	Confirmed
tan@gmail.com	CAC 0374954103 tan@gmail.com HCM HCM	iPhone 17r 256GB	15,990,000 VND	Confirmed
tan@gmail.com	CAC 0374954103 tan@gmail.com HCM HCM	Maison Francis Kurkdjian Baccarat Rouge 540 iPhone 17r 256GB	40,950,000 VND	Confirmed